

Enterprise Ransomware Investigation

Splunk SIEM Investigation Report

Cerber Ransomware Incident — Splunk BOTSv1 (Attack-Only) Dataset

Prepared by: Munachimso Okoye

Contents

1. Executive Summary
2. Scope & Methodology
3. Investigation Plan
4. Investigation Findings
5. IOC Analysis
6. MITRE ATT&CK Mapping
7. Detections
8. Incident Assessment & Recommendations

1. Executive Summary

This report documents my investigation of a ransomware incident using the Splunk BOTSv1 (Attack-Only) dataset. The investigation began with a Suricata alert for Cerber ransomware command-and-control activity. From there, I started with the alert, pivoted through the available telemetry, and built a timeline based on what the evidence showed rather than what I already knew about the dataset.

The investigation confirmed that workstation we8105desk was infected with Cerber ransomware while running under the bob.smith user account. The malware repeatedly relaunched itself under filenames that mimicked legitimate Windows binaries, escalated from Medium to High integrity, deleted Volume Shadow Copies, disabled Windows boot recovery, communicated with external command-and-control infrastructure, and spread to a network fileshare, dropping ransom notes across approximately 640 folders. From the first observed execution to the malware's self-cleanup, the incident lasted about 27 minutes.

The investigation resulted in an evidence-based attack timeline, extracted indicators of compromise, MITRE ATT&CK mapping, three reusable Splunk detections, and incident response recommendations tied directly to the findings. Where the available telemetry couldn't confirm something, including the exact initial delivery method and the specific privilege escalation technique, I stated that as a limitation rather than treating it as fact.

2. Scope & Methodology

Project Objective

Use Splunk to conduct a defensible security investigation, take security telemetry, investigate suspicious activity, establish what happened, and communicate the result the way a SOC analyst would.

Dataset

Splunk BOTSV1 — Attack-Only Dataset

Dataset Reconnaissance

Before choosing an investigation angle, I reviewed the dataset's sourcetypes and fields to understand what telemetry was actually available. The dataset covers endpoint activity (Sysmon, Windows Security, WinRegistry), network activity (Suricata, stream:* sourcetypes), and perimeter/firewall logs (FortiGate). I focused my field recon on three sourcetypes that gave the strongest coverage across timestamps, hosts, users, processes, command lines, and network connections: Suricata, WinEventLog:Security, and XmlWinEventLog:Microsoft-Windows-Sysmon/Operational.

A capability assessment against the standard SOC investigation hypotheses (initial activity, affected system/account, lateral movement, persistence, privilege escalation, exfiltration) showed strong coverage for initial detection, network analysis, and authentication/account activity, with a gap in persistence related telemetry (WinRegistry, not yet reviewed) and only partial coverage for exfiltration (flow byte counts only, no deep content inspection).

Limitations

This dataset is a training dataset, not a live enterprise environment. Throughout the investigation, I distinguished directly observed evidence from analytical inference, and noted where a finding could not be confirmed with the available telemetry.

3. Investigation Plan

Scenario

Suricata generated Cerber ransomware-related alerts within the Wayne Corp environment. I treated this the way I would on my first day on a SOC team: an alert landed in my queue, and I investigated to determine scope and impact, and whether it represented a successful compromise — without assuming the ending in

advance, even where my own dataset reconnaissance had already surfaced hints of what I'd eventually find.

Hypotheses

- What was the first suspicious activity that preceded the alerts?
- Which host(s) triggered the signatures?
- Which account(s) were active on those hosts?
- Did the activity spread to other hosts or shares?
- Was persistence established?
- Was there privilege escalation?
- What is the full scope: hosts, files, and timeline from start to finish?

4. Investigation Findings

4.1 Initial Detection

The investigation started from five Suricata alerts tied to Cerber ransomware: two 'Checkin' events, two 'Checkin Error ICMP Response' events, and two 'Onion Domain Lookup' events, all involving internal IP 192.168.250.100. I resolved this IP to hostname we8105desk using Sysmon network-connection telemetry, since the same lookup through WinEventLog:Security proved misleading (it showed the IP connecting into a different server's fileshare, not owning that IP).

4.2 Attack Reconstruction

Working backward from the confirmed C2-beaconing process, I traced the full execution chain using Sysmon process-creation events (EventID=1), following ParentProcessGuid one hop at a time. The chain revealed a self-relaunching payload that repeatedly renamed itself to mimic legitimate Windows binaries (osk.exe, explorer.exe, AdapterTroubleshooter.exe) while escalating from Medium to High integrity. The earliest identifiable execution was a file named 121214.tmp, launched with a CurrentDirectory of D:\ — circumstantially consistent with removable media as the delivery method, though not conclusively confirmed.

Hash verification confirmed that 121214.tmp and the final osk.exe instance share an identical SHA1/MD5 hash across all 7 occurrences, meaning this is one payload renamed and relaunched, not multiple distinct droppers. The two masquerading intermediate binaries (fake explorer.exe and AdapterTroubleshooter.exe) each carry their own distinct, internally consistent hash.

The full timeline is below (all times shown in Splunk _time, local display time):

Time	Host	User	Activity	Evidence	Interpretation
17:48:21	we8105desk	bob.smith	121214.tmp launched via cmd /C START, CurrentDirectory=D:\	Sysmon EventID=1	Initial execution — leading hypothesis: removable media; not confirmed
17:48:29	we8105desk	bob.smith	121214.tmp relaunches itself	Sysmon EventID=1	Self-relaunch begins
17:48:41	we8105desk	bob.smith	121214.tmp spawns osk.exe, then self-deletes	Sysmon EventID=1	Payload handoff + anti-forensics
17:48:50–17:49:01	we8105desk	bob.smith	osk.exe relaunches, spawns fake SysWOW64\explorer.exe	Sysmon EventID=1	Continued self-relaunch chain
17:49:03	we8105desk	bob.smith	Fake explorer.exe spawns	Sysmon EventID=1	Privilege escalation

			AdapterTroubleshooter.exe, relaunches at High integrity		(Medium→High)
17:49:11	we8105desk	bob.smith	Final osk.exe (C2-beaconing instance) launched	Sysmon EventID=1	Payload fully staged
17:49:23–17:49:24	we8105desk	bob.smith	vssadmin, wmic shadowcopy delete, bcdedit ×2	Sysmon EventID=1	Anti-recovery actions
17:49:24+	we8105desk	osk.exe (process)	C2 beaconing to 3 external IPs, port 6892	Suricata + Sysmon EventID=3	Cerber C2 checkin
18:04:33–18:15:11	we9041srv	bob.smith (via we8105desk)	Ransom notes dropped across 640 folders	WinEventLog:Security	Confirmed spread
18:15:11–18:15:12	we8105desk	bob.smith	Local ransom note opened	Sysmon EventID=1	Victim-facing note display
18:15:12–18:15:25	we8105desk	osk.exe (process)	Final onion-domain DNS lookups	Suricata alerts	Final C2 attempt
18:15:29	we8105desk	bob.smith	osk.exe self-deletes	Sysmon EventID=1	Final anti-forensics cleanup

Total incident duration (initial execution → final self-cleanup): approximately 27 minutes (17:48:21 → 18:15:29)

4.3 Affected Assets & Scope

- we8105desk — primary infected workstation
- we9041srv — fileshare server, 640 folders confirmed impacted
- bob.smith — the single account under which the entire chain executed

The fileshare spread was confirmed via WinEventLog:Security, showing ransom note files (# DECRYPT MY FILES #.html/.txt/.url/.vbs) written across 640 distinct folders on we9041srv's [*\fileshare](#) share, within an 11-minute window (18:04:33–18:15:11).

4.4 Ruled Out

A separate Administrator account access from IP 192.168.69.103 was observed touching the same fileshare notes during the incident window. I checked this account's history and found the same access pattern recurring at roughly 15-minute intervals going back to August 10 — well before the incident — which points to a routine scheduled process (such as monitoring or backup) rather than a second attacker or compromised admin account.

5. IOC Analysis

Network Indicators

Indicator	Type	Why Relevant
85.93.0.0	IP (C2)	Cerber C2 checkin destination, port 6892/UDP
85.93.4.54	IP (C2)	C2 destination — returned unreachable-host response
85.93.43.236	IP (C2)	C2 destination — same as above
6892/UDP	Port	Non-standard port used for all C2 checkin traffic

Onion-domain DNS lookup	DNS pattern	Fallback C2 resolution attempt via Tor-style domain
-------------------------	-------------	---

Host Indicators

Indicator	Why Relevant
AppData\Roaming\121214.tmp	Initial dropper — first observed execution of the core payload
AppData\Roaming\[GUID]\osk.exe	Core payload, renamed — final C2-beaconing instance
SysWOW64\explorer.exe	Masquerading intermediate stage
SysWOW64\...\AdapterTroubleshooter.exe	Masquerading intermediate stage — used for privilege escalation
# DECRYPT MY FILES #.*	Ransom note dropped across 640 fileshare folders

File Hashes

File(s)	SHA1	MD5
121214.tmp / osk.exe (core payload)	C8F3F0A33EFE38E9296EF79552C4CADF6CF0BDE6	EE0828A4E4C195D97313BFC7D4B531F1
SysWOW64\explorer.exe (fake)	89A175A12BC20104770D0EF83E553F8B0E06274B	40D777B7A95E00593EB1568C68514493
AdapterTroubleshooter.exe	B7202CF005748D0815A2F8B0BD1B2E681CB6C5E2	BDFABEDACD6F18B5EFB14B7529F3ED3E

The core payload hash is identical across all 7 observed occurrences (4× as osk.exe, 3× as 121214.tmp), confirming it is a single binary renamed and relaunched throughout the chain, not a set of distinct payloads.

Full IOC detail is available in [documentation/iocs.md](#) in the project repository.

6. MITRE ATT&CK Mapping

Techniques below are mapped only where the evidence directly supports a specific ATT&CK technique. Two behaviors are marked 'Not mapped' rather than assigned a best-guess technique ID, since the available telemetry didn't conclusively identify the underlying mechanism for either.

Observed Behavior	Technique	Tactic	Confidence
Execution of 121214.tmp from D:\ working directory	Not mapped — insufficient evidence for delivery mechanism	Initial Access	Low
Malware renames itself to mimic legitimate binaries	T1036 – Masquerading	Defense Evasion	High
Self-relaunch resulting in Medium→High integrity change	Not mapped — escalation mechanism not captured	Privilege Escalation	Low
Command-line execution via cmd.exe /C START	T1059.003 – Windows Command Shell	Execution	High
Deletion of Volume Shadow Copies	T1490 – Inhibit System Recovery	Impact	High
Boot recovery disabled via bcdedit	T1490 – Inhibit System Recovery	Impact	High
C2 beaconing over non-standard port	T1071 – Application Layer Protocol	Command and Control	High
DNS lookup for onion-style domain	T1071.004 – DNS	Command and Control	High
Files encrypted, ransom note dropped in 640 folders	T1486 – Data Encrypted for Impact	Impact	High
Self-deletion of payload after execution	T1070.004 – File Deletion	Defense Evasion	High

7. Detections

Three detections built from confirmed findings in this investigation. Each is intentionally kept simple — a plain search plus a table — so the query and its logic can be understood and rebuilt by an analyst with limited Splunk experience.

Detection 1: Shadow Copy Deletion (Anti-Recovery)

Detect a common ransomware precursor: deletion of Windows Volume Shadow Copies, which removes the victim's built-in recovery option before encryption begins.

```
index=botsv1 sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational"
("vssadmin.exe" OR "wmic.exe") ("delete shadows" OR "shadowcopy delete")
| spath output=EventID path=Event.System.EventID
| where EventID=1
| spath
| table _time, host, Event.EventData.Data{@Name}, Event.EventData.Data
```

Logic: Searches Sysmon process-creation events for vssadmin.exe or wmic.exe invoked with shadow-copy-deletion arguments.

Expected behavior: Should almost never fire in normal operations.

False positives: IT admins manually clearing disk space, or backup software invoking this legitimately.

ATT&CK mapping: T1490 – Inhibit System Recovery

Investigation/pivot: Check the parent process, then look for subsequent bcdedit activity and mass file modification on reachable shares.

Detection 2: Suspicious Execution of System-Named Binaries

Surface any process execution whose filename matches a common Windows system binary (osk.exe, explorer.exe), so an analyst can manually check whether it ran from its legitimate location. Also flags any execution of AdapterTroubleshooter.exe, since this is not a real Windows utility.

```
index=botsv1 sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational"
| spath output=EventID path=Event.System.EventID
| where EventID=1
| spath
| search Event.EventData.Data="*\osk.exe*" OR Event.EventData.Data="*\explorer.exe*"
OR Event.EventData.Data="*\AdapterTroubleshooter.exe*"
| table _time, host, Event.EventData.Data
```

Logic: Simple keyword search for the filenames in raw process-creation data. No path-validation logic built in — this is a triage query, not an auto-alert.

Expected behavior: Returns both legitimate and illegitimate instances. Check osk.exe against C:\Windows\System32\, explorer.exe against C:\Windows\. Any AdapterTroubleshooter.exe result is inherently suspicious.

False positives: Legitimate uses of osk.exe/explorer.exe from correct paths will also appear.

ATT&CK mapping: T1036 – Masquerading

Investigation/pivot: Check ParentImage and network connections (Sysmon EventID=3) for the ProcessGuid of any suspicious result.

Detection 3: C2 Beaconsing to Known-Bad Infrastructure

Surface network-level trojan/C2 alerts so an analyst can quickly see which internal hosts are communicating with known-malicious infrastructure.

```
index=botsv1 sourcetype=suricata alert.category="A Network Trojan was detected"  
| table _time, src_ip, dest_ip, dest_port, alert.signature
```

Logic: Filters on Suricata's alert category for network trojan detections — relies on Suricata's own signature matching.

Expected behavior: Should rarely fire in normal operations.

False positives: Low, since this relies on curated IDS signatures rather than heuristics.

ATT&CK mapping: T1071 – Application Layer Protocol (Command and Control)

Investigation/pivot: Pivot from `src_ip` to Sysmon EventID=3 to find the responsible process, then EventID=1 to trace the process chain.

8. Incident Assessment & Recommendations

What Happened

A ransomware infection (Cerber) executed on workstation `we8105desk`, escalated its own privileges, disabled Windows recovery mechanisms, communicated with external command-and-control infrastructure, and spread to a network fileshare, dropping ransom notes across 640 folders.

How Confident Am I

High confidence on the chain from initial payload execution through C2 beaconing, privilege escalation, anti-recovery actions, and fileshare spread — all directly observed in Sysmon and Suricata telemetry with consistent, corroborating hashes and timestamps. Lower confidence on the true initial delivery vector, since I didn't investigate USB device telemetry as part of this project, and on the precise privilege-escalation mechanism, since I traced the integrity-level change but not the specific technique behind it.

Containment

- **Isolate `we8105desk` from the network immediately:** confirmed active C2 communication with three external IPs
- **Disable or reset `bob.smith`'s credentials:** this account was used throughout the entire attack
- **Verify ransomware activity has stopped on `we9041srv`:** 640 folders were already confirmed impacted

Eradication

- **Remove the known-malicious binaries from `we8105desk` by hash:** see Section 5, IOC Analysis
- **Perform a full artifact sweep of `we8105desk`:** this investigation traced specific process chains, not an exhaustive host-wide sweep — persistence locations (Registry Run keys, scheduled tasks, startup folder) should still be checked
- **Re-image `we8105desk` rather than attempting selective cleanup:** the malware's repeated self-relaunch behavior creates real risk of residual components
- **Check whether other hosts show the same hashes or contacted the same C2 IPs:** this investigation was scoped to `we8105desk` only

Recovery

- **Restore affected fileshare folders from backup:** the workstation's own shadow copies were deleted; confirm we9041srv has independent, unaffected backups
- **Confirm bcdedit boot-recovery settings are restored on we8105desk:** before returning the host to service

Prevention

- **Deploy the three detections from Section 7 into production alerting:** shadow copy deletion, process masquerading, and C2 beaconing
- **Restrict or monitor execution from removable media:** the leading (unconfirmed) hypothesis for initial access
- **Review whether bob.smith's account had broader fileshare access than necessary:** 640 reachable folders is a large blast radius for one compromised account

Conclusion

This investigation traced a complete ransomware attack chain from a single Suricata alert to a confirmed, scoped incident: one infected workstation, one compromised account, and 640 impacted fileshare folders, all within a 27-minute window. Every finding in this report is tied to specific log evidence, and every place where the evidence fell short of a full answer is stated as a limitation rather than papered over. The resulting detections and recommendations are built directly from what this investigation found, not generic best practice.